



SECURITY AWARENESS

PHISHING DETECTION & AWARENESS REPORT

Email Threat Analysis · Risk Classification · Prevention Guidelines

PREPARED BY

NISHALINI

Security Analyst | Awareness Specialist

ROLE	Security Education & Analyst
DATE	April 2026
REPORT	VA-PHISH-2026-001

EDUCATIONAL

ETHICAL

DEFENSIVE

3

Emails
Analyzed

8

Indicators
Identified

4

Risk
Levels

10+

Prevention
Tips

Confidential · For authorized recipients only · No active exploitation performed

Table of Contents

1.	Executive Summary	3
2.	About Phishing Attacks	3
3.	Phishing Email Sample Analysis	4
3.1	Sample A — Account Suspension Phishing	4
3.2	Sample B — IT Password Reset Phishing	5
3.3	Sample C — Prize / Reward Phishing	6
4.	Phishing Indicators Identified	7
5.	Risk Classification Framework	8
6.	How Phishing Attacks Work	9
7.	Email Header Analysis	9
8.	Prevention Guidelines & Dos and Don'ts	10
9.	Employee Awareness Checklist	11
10.	Conclusion & Recommendations	12

1. Executive Summary

This **Phishing Detection & Awareness Report** was prepared by **NISHALINI** as part of a security education and analysis exercise. Phishing remains one of the most prevalent and damaging cyber threats faced by individuals and organisations globally. According to industry data, over **90% of successful data breaches begin with a phishing email**.



All three phishing email samples analysed were classified as **HIGH RISK**. The report provides plain-language explanations, identification indicators, and practical prevention guidelines suitable for employee awareness training.

2. About Phishing Attacks

Phishing is a form of social engineering where an attacker impersonates a trusted entity (a bank, employer, or technology company) via email to trick the recipient into revealing sensitive information, clicking a malicious link, or downloading malware.

Type	Description	Example Target
Email Phishing	Mass emails impersonating brands	Any email user
Spear Phishing	Targeted attack on a specific individual	Executives / HR
Whaling	Phishing targeting C-suite executives	CEO / CFO
Vishing	Voice/phone-based phishing	Call centre users
Smishing	SMS/text message phishing	Mobile users
Clone Phishing	Duplicate of a legitimate email with malicious links	Existing contacts

Why it works: Phishing exploits human psychology — urgency, fear, curiosity, and trust — rather than technical vulnerabilities. Even technically savvy users can be deceived by well-crafted phishing emails.

3. Phishing Email Sample Analysis

3.1 Sample A — Account Suspension Phishing

FROM: security-alert@secure-account-verify.com
TO: user@company.com
SUBJECT: ■■ Urgent: Your Account Will Be Locked

Dear User,

We noticed suspicious activity on your account.
To avoid account suspension, please verify your details immediately.

■ **Verify Now:** [http://secure-account-verify\[.\]com/login](http://secure-account-verify[.]com/login)

Failure to verify within **24 hours** will result in permanent account lock.

Regards,
Security Team

Indicators identified in Sample A:

#	Indicator	Detail	Risk
1	Fake sender domain	secure-account-verify.com — not an official domain	HIGH
2	Urgency language	"24 hours" deadline to create panic and rush the victim	HIGH
3	Generic greeting	"Dear User" — legitimate services use your real name	MEDIUM
4	Suspicious URL	Link domain does not match any legitimate organisation	HIGH
5	Fear-based threat	"Permanent account lock" — emotional manipulation tactic	HIGH
6	Vague sender name	"Security Team" — no organisation name or contact details	MEDIUM

■ **VERDICT:** HIGH RISK PHISHING EMAIL — Account suspension scam designed to steal login credentials. DO NOT click any links. Report immediately to your IT/security team.

3.2 Sample B — IT Department Password Reset Phishing

FROM: it-support@company-helpdesk-portal.net
TO: employee@yourcompany.com
SUBJECT: [ACTION REQUIRED] Password Expiry – Reset Now

Dear Employee,

Your corporate password will expire in **2 hours**. You must reset your password immediately to avoid being locked out of company systems.

■ **Reset Password:** <http://company-helpdesk-portal.net/reset?token=X9F2K>

If you do not reset your password, your account will be disabled and you will need to contact HR to reinstate access. This may affect your payroll.

IT Support Team
Your Company Name

Indicators identified in Sample B:

#	Indicator	Detail	Risk
1	External domain impersonating	company-helpdesk-portal.net ≠ yourcompany.com	HIGH
2	Extreme time pressure	"2 hours" — much shorter window to increase panic	HIGH
3	Payroll threat	Mentioning payroll impact escalates emotional pressure	HIGH
4	Token in URL	?token=X9F2K used to track victims and prefill forms	HIGH
5	Vague company name	"Your Company Name" — placeholder reveals template origin	MEDIUM
6	No sender verification	No digital signature, no SPF/DKIM alignment visible	MEDIUM

■ **VERDICT: HIGH RISK PHISHING EMAIL** — Corporate credential harvesting. Attackers impersonate IT helpdesk to steal employee login credentials. Real IT teams never ask for passwords via email.

3.3 Sample C — Prize / Reward Phishing

FROM: winner-notification@global-rewards-claim.com

TO: undisclosed-recipients

SUBJECT: ■ Congratulations! You have been selected – Claim your ■50,000 reward

Dear Lucky Winner,

You have been randomly selected to receive a reward of ■50,000 from our Global Customer Appreciation Programme.

To claim your prize, click below and fill in your bank details for direct transfer:

■ **Claim Reward:** [http://global-rewards-claim\[.\]com/claim-now](http://global-rewards-claim[.]com/claim-now)

This offer expires in **48 hours**. Limited slots available. Do not share this email with anyone.

Warm regards,

Global Rewards Team

Indicators identified in Sample C:

#	Indicator	Detail	Risk
1	Too-good-to-be-true offer	Unsolicited prize reward — classic advance-fee scam	HIGH
2	Unknown fabricated domain	global-rewards-claim.com — no legitimate organisation	HIGH
3	Request for bank details	Asking for financial information to 'transfer' funds	HIGH
4	Secrecy instruction	"Do not share this email" — isolates victim from help	HIGH
5	BCC / undisclosed recipients	Mass phishing campaign, not targeted communication	MEDIUM
6	Artificial scarcity	"Limited slots available" — pressure tactic	MEDIUM

■ **VERDICT:** HIGH RISK PHISHING EMAIL — Advance-fee / financial fraud attempt. Designed to steal bank details or demand upfront 'processing fees'. Never provide bank details in response to unsolicited emails.

4. Phishing Indicators Identified

The following table consolidates all phishing indicators observed across the three email samples. These red flags collectively form a detection checklist for end users and analysts.

Indicator	Description	Frequency	Risk
Suspicious/Fake Domain	Sender domain does not match the organisation it claims to represent	2/3	HIGH
Urgency / Time Pressure	Artificial deadlines (2h, 24h, 48h) used to prevent careful thought	3/3	HIGH
Fear-based Threats	Account lock, payroll disruption, or lost opportunity as leverage	3/3	HIGH
Generic Greeting	"Dear User" or "Dear Employee" instead of the recipient's real name	2/3	MEDIUM
Suspicious Hyperlink	URL domain has no relation to the claimed sender organisation	3/3	HIGH
Request for Sensitive Data	Credentials, bank details, or OTPs requested via email	2/3	HIGH
Secrecy Instruction	Instruction not to share or forward the email to avoid detection	1/3	HIGH
No Digital Signature	No DKIM/S-MIME signature — email authenticity cannot be verified	2/3	MEDIUM
Emotional Manipulation	Lottery win, fear of financial loss, or threat of job impact	3/3	HIGH
BCC / Mass Recipient	Sent to undisclosed recipients — bulk campaign, not personalised	1/3	MEDIUM

5. Risk Classification Framework

Each analysed email is assigned a risk classification based on the number and severity of phishing indicators present.

Classification	Criteria	Action Required
■ SAFE	No phishing indicators. Sender verified. Legitimate content.	No action needed. Normal processing.
■ SUSPICIOUS	1–2 low-severity indicators. Unusual but may be legitimate.	Verify sender via alternative channel before responding.
■ LIKELY PHISHING	3–4 indicators including domain or link anomalies.	Do not click links. Report to IT/security team.
■ HIGH RISK PHISHING	5+ indicators including fake domain, credential request, urgency.	Delete immediately. Report to security team. Warn contacts.

Classification results for analysed samples:

Email Sample	Indicators Found	Classification	Verdict
Sample A — Account Suspension	6 indicators	■ HIGH RISK PHISHING	PHISHING
Sample B — IT Password Reset	6 indicators	■ HIGH RISK PHISHING	PHISHING
Sample C — Prize / Reward	6 indicators	■ HIGH RISK PHISHING	PHISHING

6. How Phishing Attacks Work — Plain English

Step 1 Attacker creates a fake email	The attacker registers a domain that looks similar to a real company (e.g., company-helpdesk-portal.net instead of company.com) and crafts a convincing email.
Step 2 Victim receives the email	The email lands in the victim's inbox, often bypassing spam filters because it uses legitimate email infrastructure or spoofed headers.
Step 3 Victim clicks the malicious link	Urgency language pressures the victim to act quickly without checking carefully. They click the link and are taken to a fake website.
Step 4 Fake website captures credentials	The victim enters their username, password, OTP, or bank details into a realistic-looking fake login page. This data is immediately sent to the attacker.
Step 5 Attacker exploits stolen information	With stolen credentials, the attacker can access accounts, steal money, send further phishing emails from the victim's address, or sell the data on dark web marketplaces.

7. Email Header Analysis

Email headers contain technical metadata about an email's origin, routing, and authentication. Analysing headers can reveal whether an email is genuinely from the claimed sender.

Header Field	What It Shows	Red Flag to Look For
From:	Claimed sender address	Domain doesn't match official domain
Reply-To:	Where replies are directed	Different from 'From' address
Received:	Mail server routing path	Unknown or foreign mail servers
X-Originating-IP	IP address of sending machine	IP geolocates to unexpected country
SPF Result	Was sender authorised to send?	FAIL or SOFTFAIL = suspicious
DKIM-Signature	Cryptographic email signature	Missing or invalid = unverified

DMARC Result	Overall policy alignment	FAIL = email likely spoofed
Message-ID:	Unique email identifier	Random characters or unusual format

Free tools for header analysis: Google Admin Toolbox (toolbox.googleapps.com/apps/messageheader/) | MXToolbox (mxtoolbox.com/EmailHeaders.aspx) — paste the full email header to get a detailed breakdown.

8. Prevention Guidelines & Dos and Don'ts

■ DO	■ DON'T
✓ Verify the sender's email domain carefully before clicking any link.	✗ Click links in unsolicited emails, even if they look legitimate.
✓ Hover over links to preview the actual URL before clicking.	✗ Enter your username, password, or OTP on a page reached via an email link.
✓ Contact the sender directly via phone or official website if an email seems suspicious.	✗ Download attachments from unknown or unverified senders.
✓ Report suspicious emails to your IT/security team immediately.	✗ Share sensitive information (passwords, OTPs, card details) via email.
✓ Keep your email client, browser, and antivirus software up to date.	✗ Forward suspicious emails to colleagues — you may spread the attack.
✓ Enable Multi-Factor Authentication (MFA) on all accounts.	✗ Assume an email is safe because it passed your spam filter.
✓ Attend regular security awareness training provided by your organisation.	✗ Ignore security warnings from your browser about unsafe sites.
✓ Use a password manager — phishing sites cannot autofill on wrong domains.	✗ Use the same password across multiple accounts.
✓ Check for HTTPS and the correct domain name on any login page you visit.	✗ Trust an email solely because it contains your company logo.
✓ When in doubt, delete and verify — never act on urgency in an email.	✗ Act on threats or prizes communicated only through email.

9. Employee Awareness Checklist

Print or share this checklist with all employees. Before taking any action on an email, work through each question. If you answer YES to any red flag, treat the email as suspicious.

Before You Click — Ask Yourself	GREEN FLAG ■	RED FLAG ■
Does the sender's domain match the official company website?	Matches exactly	Uses a lookalike domain
Were you expecting this email?	Yes, you initiated contact	No, arrived unexpectedly
Does it address you by your real name?	Yes, uses your full name	Says 'Dear User' or 'Dear Customer'
Is there urgent language or a short deadline?	No urgency mentioned	Threatens lockout, fine, or prize expiry
Does the link URL match the claimed organisation?	Yes, official domain on hover	Different or suspicious URL
Is the sender asking for a password, OTP, or bank details?	No sensitive info requested	Yes — immediate red flag
Does the email have a valid digital signature (DKIM)?	Verified signature present	No signature or signature invalid
Is the grammar and formatting professional?	Clean, professional language	Typos, odd formatting, excessive emojis
Does clicking the link feel urgent or forced?	Link is optional/informational	Email insists you MUST click now
Can you verify this email via another channel (phone/web)?	Confirmed via official contact	No way to verify independently

■ If 3 or more RED FLAGS are present: DO NOT click, DO NOT reply, DO NOT forward. Forward the email as an attachment to your security/IT team and delete it from your inbox.

10. Conclusion & Recommendations

This report demonstrates that phishing emails share consistent, identifiable patterns. By training employees to recognise these patterns, organisations can dramatically reduce the risk of a successful phishing attack.

Key findings:

- All 3 email samples analysed were classified as **HIGH RISK PHISHING** with 6+ indicators each.
- The most consistent indicators were: fake domains, urgency language, generic greetings, and suspicious links.
- No sample contained a verified DKIM signature — a reliable technical red flag.
- All three attacks relied on emotional manipulation (fear, greed, or authority) rather than technical exploits.

Organisational recommendations:

Priority	Recommendation	Who
1 — Immediate	Deploy phishing simulation campaigns quarterly	IT / Security Team
2 — Immediate	Enable MFA on all email and business accounts	IT Admin
3 — Short-term	Configure SPF, DKIM, and DMARC on your email domain	IT Admin
4 — Short-term	Conduct a 30-min phishing awareness session annually	HR / Security
5 — Ongoing	Subscribe to threat intelligence feeds for new tactics	Security Team
6 — Ongoing	Create a simple one-click 'Report Phishing' button	IT / Microsoft/Google

■ Remember: Technology alone cannot stop phishing. The strongest defence is an **informed, alert, and empowered employee**. Share this report and checklist with your team.

Prepared by:	NISHALINI
Role:	Security Analyst & Awareness Specialist
Date:	April 2026
Report Ref:	VA-PHISH-2026-001